WEBSITE BLUEPRINT · VERSION 3.2

Prospect Road Community Fund

Pledges and giving plans, secure payments, a live public ledger and statements, staff tools for five people, treasurer limits and goals, goal prompts, temporary developer access, an activity log, refunds, closing the fund with exact payouts, and an automated test system.

Updated October 17, 2026 · Manatee County, Florida
Everything (code, tests, launch checklist, handover guide and this blueprint) is in one file:
Community_Fund_Website_v3.2.zip

Contents

1. Summary and what changed in v3
2. Two versions: when to use each
3. Pages and journeys
4. Team roles
5. Design
6. Architecture
7. Data model
8. Money logic
9. Refunds, disputes and closing
10. Emails
11. Security and privacy
12. Search and discoverability
13. Accessibility, performance and scale
14. Compliance
15. Quality assurance
16. Launch plan and costs
17. Operating the fund
18. File index
19. Giving plans, limits and goal prompts
20. Developer access, handover and activity log

1 Summary and what changed in v3

One website where neighbors pledge, pay securely and can check how every dollar is used, with tools for up to five volunteers to run the books.

$10,000
Milestone 1: retain a land use attorney

$1,700,000
Milestone 2: match the land's A-1 value

$2,000,000
Full target: buy the land and open a community park

Response to the code review

Every gap the reviewer listed has been built into the existing code and covered by automated tests. No rebuild was needed: the database, payment flow and pages already matched the blueprint.

REVIEWER'S POINT	NOW IN THE CODE	TESTED BY
Refund and dispute handling	Card refunds from the console through Stripe; manual refunds; Stripe refunds and chargebacks picked up automatically; disputed payments flagged; fees recorded; treasurer alerted	Unit, database, browser
Pledge management	Edit amount, date and note; withdraw; cancel; reinstate. Status (open / partly paid / paid) recalculated by the database	Database, browser
Closing the fund and paying out	Closing tab: stop pledges, exact payout plan to the cent, board-approval CSV, record each payout, email it, mark closed	Database, browser
Confirmation and receipt emails	Pledge confirmation, payment receipt, deposit receipt, refund and payout notices, dispute alerts; every attempt logged	Unit
Full audit log and books export	Paged, filterable audit log in plain words; downloads of the double-entry journal, deposits, refunds, expenses, pledges, contributors, audit and email logs, with no row limit	Database, browser

Correct or delete contributor data	Edit details (public lines update everywhere), combine duplicates, erase on request (also scrubbed from audit history)	Database, browser
Content pages	Updates (written in the console), The Live Local Act explainer, Park vision	Browser
Automated tests	159 tests in 4 suites plus a pre-deploy check; one command runs them all	Section 15
Privacy issue	Fixed: entering someone else's email on the pledge form used to show their private share link. It is now emailed only to the address on file	Unit (fails if the bug returns)
Scaling issue	Fixed: totals were added up in the server from at most 5,000 rows, and Supabase returns only 1,000 per request. Totals are now computed inside the database: exact at 20,000 entries in 0.16 seconds	Database scale test

Second review: hardening before real money (v3.1)

ITEM	NOW IN THE CODE	TESTED BY
Group neighborhood names correctly	Spelling tidied by the database ("magnolia pt" → "Magnolia Point"); treasurer can merge nicknames; future entries follow	Database, browser
Enforce the registration rule on the server	The database refuses to switch on card payments without a valid registration number, and checkout refuses too	Database, unit
Protect the audit log from changes	No one (staff, server, or database owner) can edit, delete or empty it; each entry is sealed to the one before it, so tampering is detected and pinpointed	Database, browser
Check security headers after deployment	`npm run verify -- https://yourdomain.org`: 16 checks on the live site	Unit (good and broken sites)
Testing with real services	Step-by-step launch checklist: test mode first, then a $1 live payment and refund	`docs/LAUNCH_CHECKLIST.md`

Third update: what changed in v3.2

REQUEST	NOW IN THE CODE	TESTED BY
Many small donations over time	Giving plans: weekly, monthly or every 3 months for a set number of payments, by card (Stripe subscription that ends itself after the last payment) or collected by hand. Donors can stop a plan, give again or pay what they still owe from their private link	Unit, database, browser
Treasurer raises or lowers limits and goals	Settings: smallest gift, largest card payment, largest website pledge, largest hand-recorded deposit, plans on/off and length, suggested amounts; goals added, raised, lowered or removed. The database enforces every limit	Unit, database, browser
Dynamic prompts and targets	"What it will take" on the home page, worked out from the live figures: amount to go, pledges in hand, how many gifts or plans close the gap, plan pace, a daily target to a chosen date, and the leading neighborhood. Treasurer can set a headline and date or switch it off	Unit, browser
Handover; developer invited back and removable at any time	Developer role: one at a time, 1 to 30 days, stated purpose, sees only system checks and the activity log (no people or money), removed and blocked from sign-in with one click. Handover checklist in the console; confirming it removes all developer access	Unit, database, browser
Close all backdoors	Database lockdown (public key can run no function), owner-check bug class removed, development shortcuts only on a laptop, and a backdoor sweep that fails the build if any endpoint lacks a guard or a bypass switch appears	Database, unit, pre-deploy check
Running activity log	Sign-ins, downloads, team and settings changes, handovers, refused access, forged payment notices, payment failures and server errors; append-only and sealed entry to entry; problems banner for the treasurer	Unit, database, browser
Retest everything	232 automated tests plus the pre-deploy check, all passing; each new safeguard checked against a planted bug	Section 15

2 Two versions: when to use each

	A. LIVE FUND PAGE (ON CLAUDE)	B. PUBLIC WEBSITE (CODE PACKAGE)
Status	Published. An update adding staff entry, team activity and statistics is ready but not yet published	Ready to deploy (about an hour of setup)
Who can use it	People you share it with, signed in to Claude; up to 4 helpers with Edit access	Anyone; staff sign in with an emailed code
Payments	Link to your payment page	Stripe Checkout; refunds and disputes handled
Emails, refunds, closing	Not included	Included
Search engines	Not indexed	Fully indexable
Best use	Committee and early pledges now	The public campaign

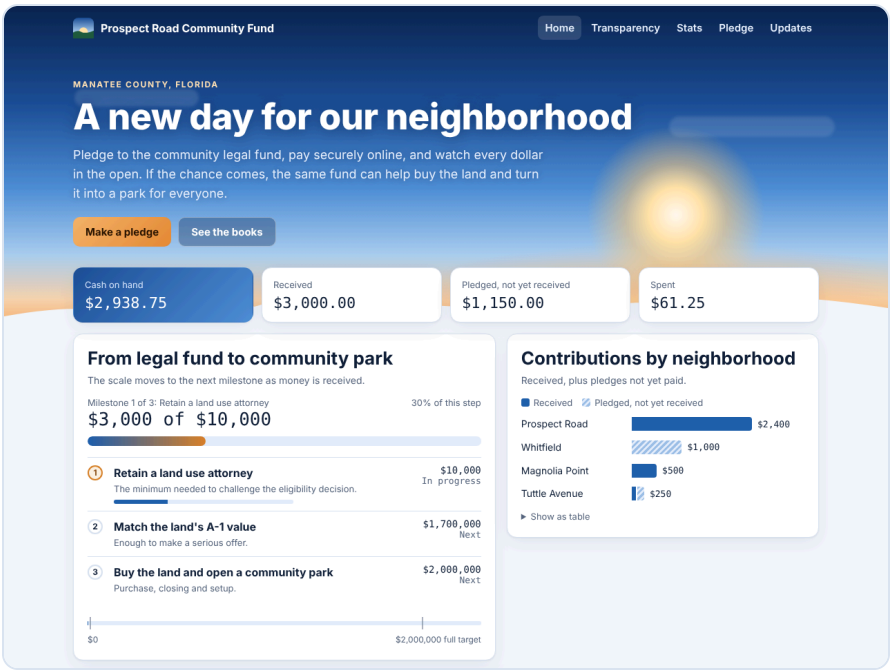


Figure 1. Home page. Sample figures for illustration only.

3 Pages and journeys

PAGE	ADDRESS	PURPOSE	IN SEARCH
Home	/	Story, totals, milestone scale, neighborhood chart, pledge form, FAQ	Yes
Transparency	/transparency/	Income, refunds, expenses, statements, refund shares, full CSV	Yes
Statistics	/stats/	By community, over time, gift sizes, methods, spending, months	Yes
Updates	/updates/	Dated news written in the staff console	Yes
The Live Local Act	/live-local-act/	Plain-language explainer and the site's eligibility question	Yes
Park vision	/park/	The nature-park idea and the $2M milestones	Yes
Privacy	/privacy/	What is collected and who sees it	Yes
My share, Thank you, 404	/share/ /thanks/	Private link (plans, give again, pay what is owed); after payment; not found	No
Staff console	/admin/	Record · Pledges (and giving plans) · Money in and out · People · Closing · Updates · Audit and exports · Team · Settings · System and activity	No

Neighbor

1. Pledges on the website (bot check)
2. Gets a confirmation email with a private link
3. Pays by card on Stripe, or by check/Zelle/cash
4. Gets a receipt email; appears as "First L., Neighborhood"

Recorder (helper)

1. Signs in with an emailed code
2. Searches for the person or adds them
3. Records a paper pledge or a deposit; the amount owed is suggested
4. A receipt is emailed; everything updates within a minute

4 Team roles

At most 5 active people, plus one temporary developer when the treasurer invites one. The database enforces the limits and always keeps one active treasurer.

ACTION	TREASURER	RECORDER	AUDITOR	DEVELOPER
See the books, contributors, audit log; download exports	Yes	Yes	Yes	No
Record pledges, deposits and hand-collected plans; email receipts	Yes	Yes	No	No
Edit, withdraw or cancel pledges; stop giving plans; delete entries	Yes	No	No	No
Expenses, refunds, payouts, closing the fund	Yes	No	No	No
Correct, combine or erase contributor data	Yes	No	No	No
Updates; settings, limits and goals; team; invite or remove a developer; confirm handover	Yes	No	No	No
Activity log	Yes	No	Yes	Yes
System health and security checks	Yes	No	No	Yes

The page only hides buttons; the real enforcement is in the database (row-level security), tested for every role. A deactivated person loses access at once. Every change is stamped with who made it.

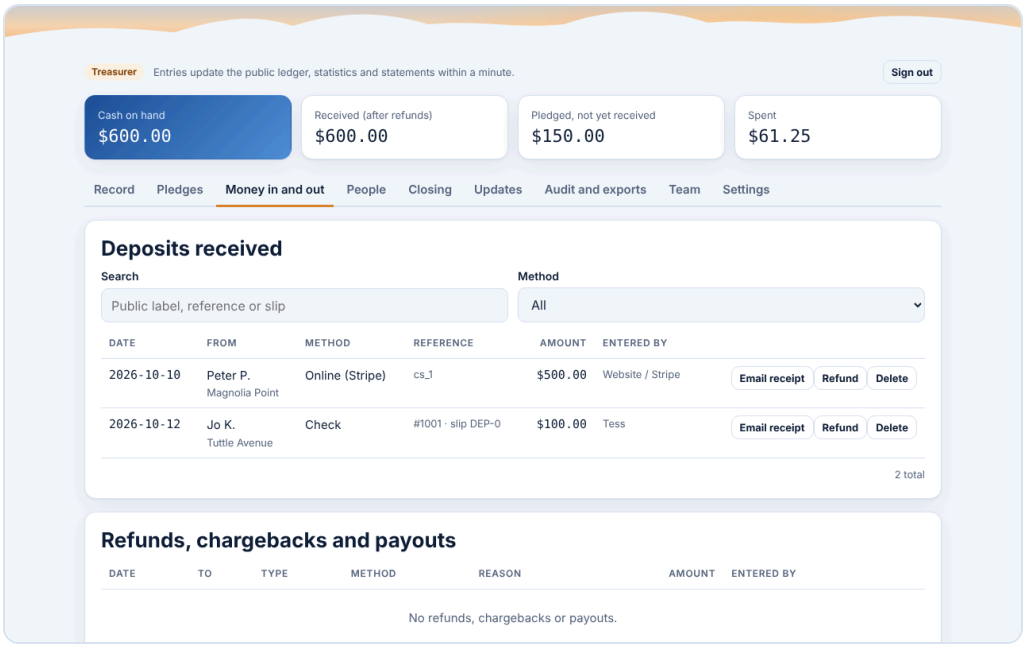


Figure 2. Staff console, "Money in and out", showing who entered each line and the Refund buttons.

5 Design

Blue sunrise sky: calm, hopeful, civic. Light and dark modes are designed separately.

TOKEN	LIGHT	DARK	USED FOR
Sky gradient	#0B2550 → #4F8FD6 → #F4A65C	#030A18 → #1D4F97 → #D98A4A	Hero, cover, social image, emails
Primary blue	#1F5FAE	#7FB2EF	Buttons, bars, links
Sunrise accent	#D9822B	#F2A85C	Pledge button, current milestone, focus ring

Charts use one hue with a hatched texture for pledges (never colour alone), values at bar tips, keyboard tooltips and a table view.

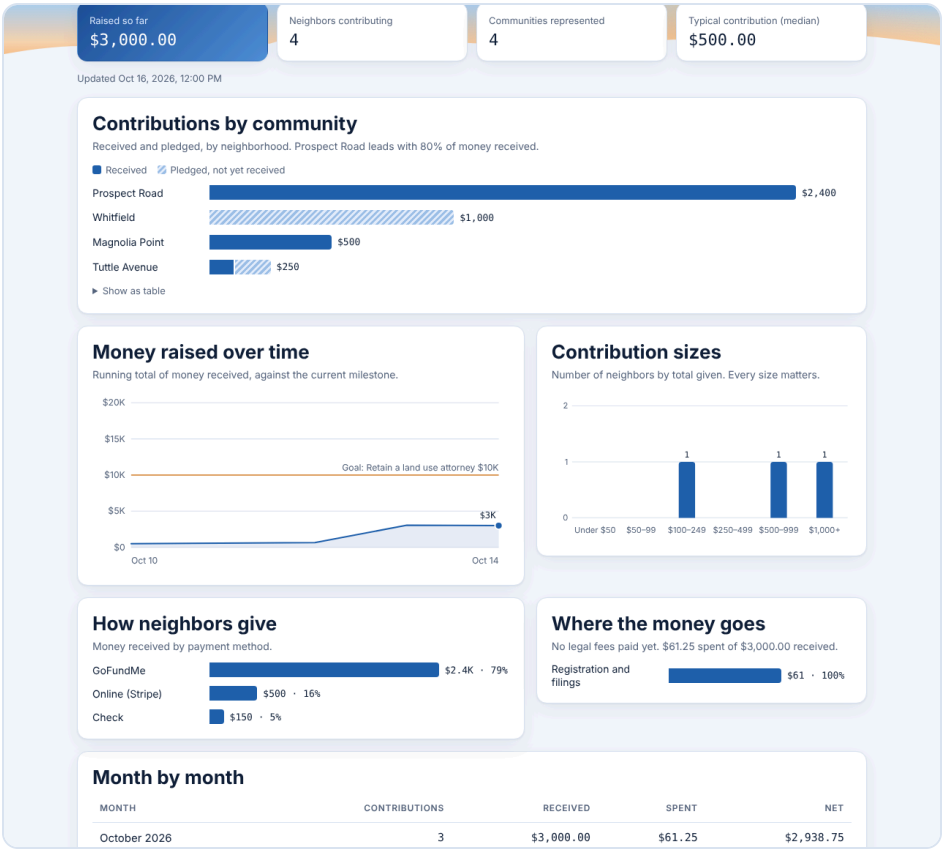
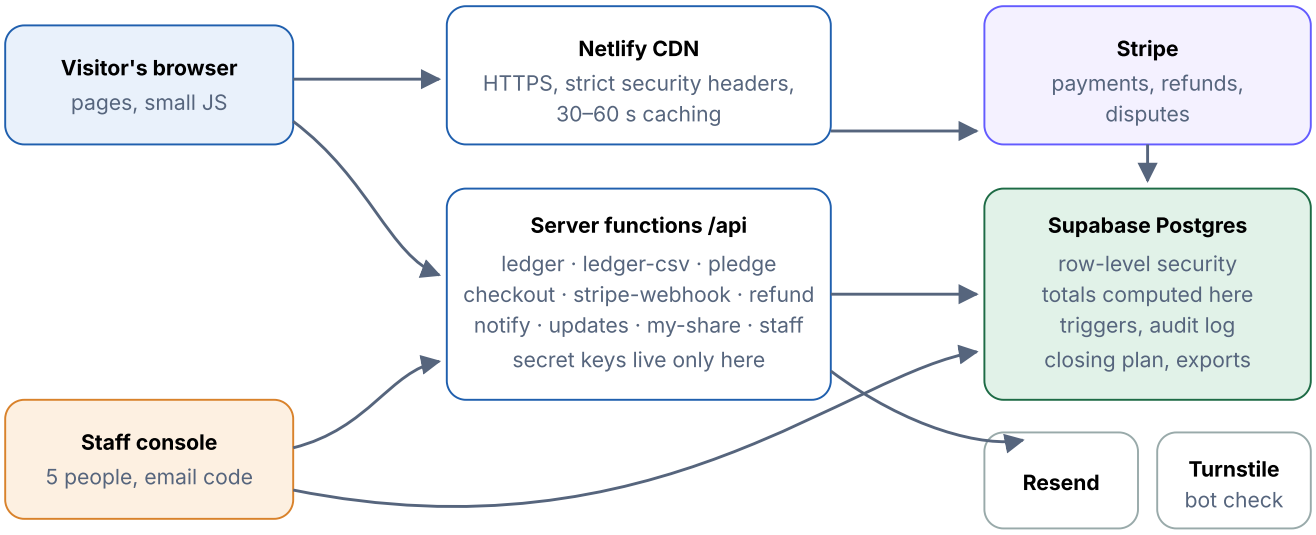


Figure 3. Statistics page. Sample figures.

6 Architecture



ENDPOINT	WHO	DOES
`GET /api/ledger`	Public	All public figures from one database function; cached at the edge
`GET /api/ledger-csv`	Public	Every public entry as CSV, paged 1,000 rows at a time
`POST /api/pledge`	Public	Validates, bot-checks, saves, emails a confirmation
`POST /api/checkout`	Public	Stripe payment for what is still owed (from the database)
`POST /api/stripe-webhook`	Stripe	Payments, refunds, disputes; signature-checked, idempotent
`POST /api/refund`	Treasurer	Card refund through Stripe; records it; emails the person
`POST /api/notify`	Recorder+	Sends a receipt, refund or payout email; server picks recipient and content
`/api/staff`	Treasurer	List, add, change role, deactivate (5-seat limit)
`GET /api/updates, /api/my-share`	Public	Published news; a contributor's own share by private link

7 Data model

TABLE	HOLDS	READ	WRITE
contributors private	Name, email, address, area, public label, private link token	Staff	Website, recorder (add), treasurer
pledges	Amount, date, status (open / partial / paid / withdrawn / cancelled), note	Staff	Website, recorder (add), treasurer
receipts	Money received: amount, date, method, private reference and deposit slip, dispute flag, Stripe ids	Staff; public columns via API	Webhook, recorder (add), treasurer
refunds	Refunds, lost chargebacks and closing payouts; never more than what is left of a receipt	Staff; public via API	Webhook, treasurer
expenses	Payee, category, description, paid or unpaid	Staff; public via API	Webhook (fees), treasurer
posts	Updates: title, address, summary, text, published	Staff; published via API	Treasurer
settings	Name, registration number, milestones, online payments, fund status (open / closing / closed)	Staff; public via API	Treasurer
admins	Team: role, name, active	Staff	Server only (treasurer)
audit_log, **email_log**	Every change (who, when, before, after); every email attempt	Staff	Triggers / server only

Database functions

- **public_ledger** – every public figure in one pass: totals, communities, people, months, daily totals, gift sizes, recent lists.
- **closing_plan** – each contributor's share of what is left, rounded so the payouts add up exactly.
- **export_journal** – a balanced double-entry journal for an accountant.
- **anonymize_contributor**, **merge_contributors** – personal-data tools (treasurer only).
- Triggers keep pledge status, public labels, the five-seat limit and the audit log correct automatically.

8 Money logic

FIGURE	FORMULA
Net contributions ("Received")	All money received − refunds − lost chargebacks
Cash on hand	Net contributions − paid expenses − payouts already made
Net assets	Cash − unpaid bills
Pledged, not yet received	Per person: pledges (not withdrawn or cancelled) − their net contributions, never below 0
Available to return	Net contributions − all expenses − payouts already made
Person's share and refund	Their net contribution ÷ all net contributions, × available to return

Worked examples (both run by the tests)

CASE	RESULT
One person gives $100; $100 spent	$0.00 to return
Two people give $100 each; $100 spent	$50.00 each
Three people give $100 each; $200 spent; fund closes	$33.34 + $33.33 + $33.33 = exactly $100.00
Pledge $100, receive $100, refund $40	Pledge goes from "paid" back to "partly paid"; $40 shown as owed

> Money received is applied to a person's pledges oldest first. Status is recalculated by the database whenever money is recorded, refunded, edited or deleted, so every page, statement and export always agrees.

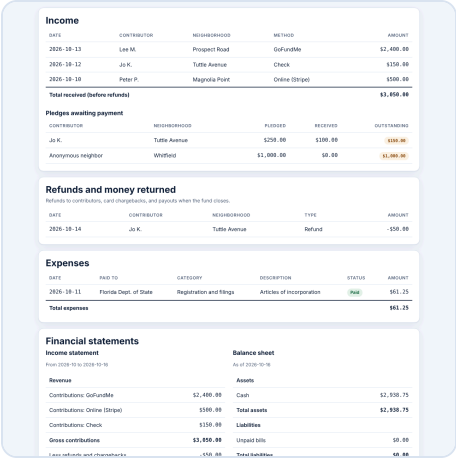


Figure 4. Transparency page: refunds and net figures. Sample figures.

9 Refunds, disputes and closing the fund

Refunds

- Card payment: Money tab › Refund. The server refunds through Stripe and records it
- Check, Zelle, cash: Refund records how it was repaid
- Refunds started in the Stripe dashboard are picked up automatically
- Never more than what is left of the original payment
- The person is emailed

Disputes (chargebacks)

- Payment marked "Under dispute" in the books
- Stripe's dispute fee recorded as an expense
- Treasurer emailed to respond in Stripe
- Won: flag cleared (fee removed if Stripe returns it)
- Lost: recorded as a chargeback; pledge re-opens

Closing, step by step

1. **Stop new pledges.** The website and checkout refuse new pledges; the home page explains why.
2. **Pay the last bills.** The console warns while any bill is unpaid.
3. **Download the payout plan** (CSV) for the board to approve.
4. **Record each payout** (check, Zelle, bank transfer…). Each person is emailed their amount.
5. **Mark the fund closed** and add a public closing note. Anonymous gifts with no contact details stay with the fund and are disclosed.

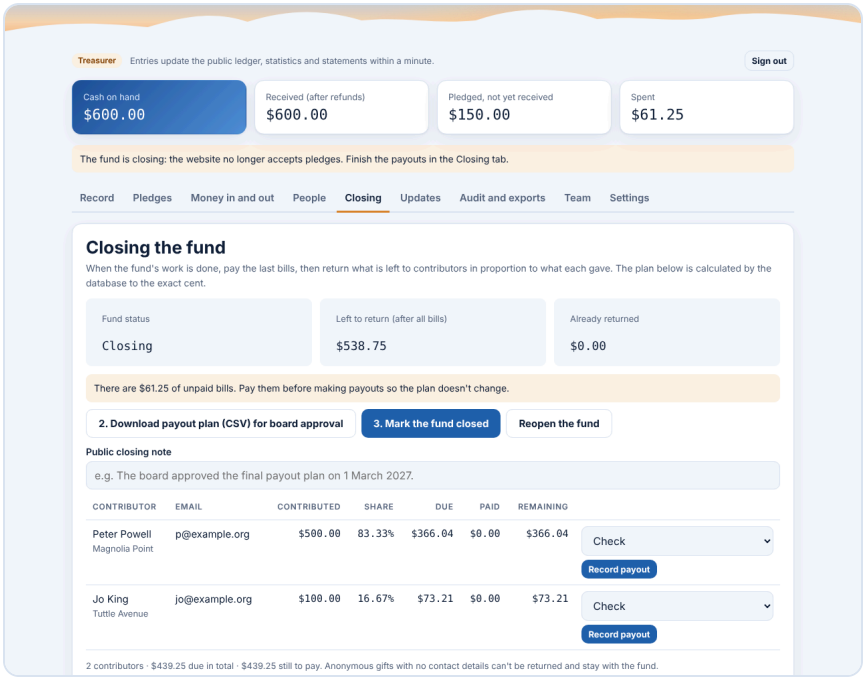


Figure 5. Closing tab with the exact payout plan.

10 Emails

EMAIL	WHEN	CONTAINS
Pledge confirmation	Website pledge	Amount, how to pay, private link (only ever to the address on file)
Payment receipt	Card payment confirmed	Amount, date, method, receipt number
Deposit receipt	Staff record a deposit (box ticked) or press "Email receipt"	Same as above
Refund notice	Refund recorded	Amount, method, reason
Payout notice	Closing payout recorded	Their share and how it is paid
Dispute alert	Card dispute opened	To the treasurer: who, how much, what to do

Every email carries the "not tax-deductible" statement and, once registered, the state's required disclosure. Emails go through Resend; without a key they are logged as "skipped" rather than lost silently. The email log can be downloaded.

11 Security and privacy

RISK	CONTROL
Card data theft	Cards only on Stripe's page (PCI SAQ A); refunds only through the server
Leaking addresses or emails	Private table under row-level security; public API returns labels and areas only; test fails if private columns appear
Revealing someone's private link or giving	**Fixed in v3:** the link is shown only to a new contributor and otherwise emailed to the address on file
Fake or altered payments	Webhook signatures; amounts from the database; duplicate events ignored
Over-refunding	The database refuses refunds above what is left of a payment
Staff account misuse	Email codes, 5 seats, roles enforced in the database, instant deactivation, audit log with names
Script injection, clickjacking, downgrade	Strict security policy (no inline scripts or styles), text-only rendering, frame blocking, HSTS
Spreadsheet formula injection	All CSV exports neutralise cells that start with = + − @
Spam and bots	Turnstile, honeypot, per-IP rate limits on every endpoint
Right to be forgotten	Erase removes name, email and address everywhere, including the audit history; money records stay for the books
Wrong totals at scale	**Fixed in v3:** totals computed in the database; exact at 20,000 entries
Altered or deleted history	**v3.1:** audit log write-protected for everyone and hash-chained; the console shows "Integrity verified" or the exact entry that was changed
Card payments before state registration	**v3.1:** enforced by the database and by checkout, not only by the screen
Misconfigured deployment	**v3.1:** post-deploy checker for HTTPS, headers, exposed files, leaked keys and open endpoints (v3.2: also health, give and plan endpoints)
Backdoors	**v3.2:** public key can run no database function; privileged functions check the caller; development shortcuts only under `netlify dev` on a laptop; the build fails on an unguarded endpoint, a bypass switch, a team member added in SQL, or a grant to the public key
A developer keeping access	**v3.2:** developer access ends on its own (max 30 days), is removable at once and blocks sign-in; handover requires account ownership transfer and new keys, and removes all developer access
Not noticing an attack or fault	**v3.2:** sealed activity log of sign-ins, refused access, forged webhooks, payment failures and errors; problems banner; system self-check

12 Search and discoverability

- Unique titles and descriptions (checked for length by the tests), one H1, canonical links, robots rules, sitemap with all 7 public pages.
- Structured data: NGO, WebSite, WebPage with DonateAction, FAQPage, Article (Live Local Act), CollectionPage (Updates).
- Open Graph and X cards with the sunrise image; web app manifest and icons.
- `llms.txt` for AI search, plus public JSON and CSV of the ledger.
- Content for the searches people make: "Prospect Road apartments", "Live Local Act Manatee", "community park Manatee County".

> After launch: verify the domain in Google Search Console and Bing Webmaster Tools, submit the sitemap, post an update at least monthly, and ask HOA and local news sites to link to the Transparency page.

13 Accessibility, performance and scale

Accessibility (WCAG 2.2 AA)

- Labels on every field, checked by the tests
- Keyboard-usable charts, tabs and contributor search
- Charts never rely on colour; table views
- Reduced motion, dark mode, high-contrast mode

Performance

- Static pages at the edge; about 15 KB of public script; no framework
- Targets: LCP under 2.5 s, INP under 200 ms, CLS under 0.1
- Ledger cached 30 s; polling pauses in background tabs

Scale (measured)

ENTRIES	BEFORE V3	V3
3,000 deposits	Totals cut off at 1,000 rows by Supabase; 10.8 s to compute in the first database version	Exact; 45 ms
20,000 deposits, 10,000 people	Wrong totals	Exact; 0.16 s; 118 KB response
Staff lists	Loaded everything at once	25 per page, server-side search

14 Compliance

Not legal advice. Confirm each item with the fund's attorney or accountant.

ITEM	WHAT TO DO	SITE SUPPORT
Florida charitable solicitation (Ch. 496)	Register with FDACS before soliciting	Card payments stay off until the number is entered
Required disclosure	Show the state's statement on solicitations	Footer and every email, automatically
Tax status	Gifts not deductible until 501(c)(3) or fiscal sponsor	Footer, FAQ, emails
Refund promise	Adopt the pro-rata rule in bylaws or a board resolution	Shares page, closing plan
Records	Keep financial records at least 3 to 7 years	Database, exports, audit log
Privacy	Honour correction and deletion requests where lawful	Edit, combine and erase tools
Audit thresholds	Larger charities need CPA-reviewed or audited statements	Double-entry journal export

15 Quality assurance

One command, `npm test`, runs everything below. Run it before every deploy.

SUITE	TESTS	WHAT IT COVERS	RESULT
Pre-deploy check	All pages	No secrets in public files; SEO tags present; nothing that breaks the security policy	**Pass**
Server (unit)	96	Validation, privacy, Stripe payments, refunds, disputes, emails, staff API, CSV export, registration rule, post-deploy checker; v3.2: limits, giving plans and their Stripe events, give again, stopping plans, developer access, expiry, health page, refused-access logging, goal prompts	**96 / 96**
Database	52	Real Postgres: access rules per role, staff limit, pledge status, refunds, closing plan, erasure, journal balance, neighborhood names, audit-log protection, upgrades from v2 and v3.1, 20,000-row scale; v3.2: limits, goals, plans, developer visibility, expiry, handover, activity log protection and tamper detection, function lockdown, security self-check	**52 / 52**
Browser end-to-end	75	Every page on phone and desktop, light and dark, under the production security policy; accessibility and SEO checks; staff console per role including developer; giving plans, prompts, limits, team, handover and activity screens	**75 / 75**
Live Claude page	9	Simulated treasurer, helper and neighbor; entries flow to every report; privacy	**9 / 9**

Problems the tests found, now fixed

- Privacy: a pledge with someone else's email returned their private link.
- Scale: public totals were capped by the 1,000-row API limit; the first database version took 10.8 s at 3,000 rows.
- Statistics showed an average instead of the median when someone had pledged but not yet paid.
- Closing buttons disappeared after confirming "stop new pledges".
- Home search description too long (189 characters) and 404 description too short; unclear consent message.
- Staff console tabs unstyled; cards touching.
- v3.1: a trailing full stop split one neighborhood into two; a type error in the first version of the audit-chain check.
- v3.2: three database functions trusted "the database owner" as the server, which inside those functions is always true; replaced with a real server check. Postgres let anyone run new functions by default; now locked down. A stopped-plan message vanished when the page refreshed. A phone layout overflowed by 15 pixels on Settings.

Each test was also checked against a deliberately planted bug, to confirm it fails when it should.

Not yet tested: the real Supabase, Stripe, Resend and Turnstile accounts (they need the fund's keys). `docs/LAUNCH_CHECKLIST.md` walks through 18 end-to-end tests in test mode (sign-in, payments, refunds, a disputed card, receipts, roles, erasure, closing) and then a $1 live payment and refund, followed by `npm run verify`.

16 Launch plan and costs

WEEK	STEP	OWNER
1	Form the nonprofit, get the EIN, open a bank account	Board
1–2	File FDACS registration; create Supabase, Stripe (test), Resend, Turnstile and Netlify accounts	Treasurer + tech volunteer
2	Deploy; connect the domain; run `npm test` and `npm run verify`; work through the launch checklist in test mode	Tech volunteer or developer
2	Add the 4 team members; record existing GoFundMe and paper pledges	Treasurer
3	Registration received: enter the number, switch Stripe to live, open payments; publish the first update	Treasurer

SERVICE	COST
Netlify hosting and functions	Free tier
Supabase database	Free, or about $25/month for daily backups and no pausing (recommended once money is coming in)
Stripe	Standard US card rate 2.9% + 30¢ per payment; ask about nonprofit pricing; dispute fees apply if a payment is disputed
Resend email	Free tier covers a community campaign
Cloudflare Turnstile	Free
Domain	About $12–$20/year

Prices change; confirm on each provider's pricing page.

17 Operating the fund

Weekly

- Record GoFundMe payouts, checks, Zelle and cash (receipts emailed)
- Match bank deposit slips to deposits
- Record and pay bills
- Check for disputes

Monthly

- Reconcile the bank balance to "Cash on hand"
- Auditor reviews the audit log
- Board reviews statements; download the journal
- Post an update

Requests from contributors

- Correct details: People › Edit
- Duplicate records: People › Combine
- Delete my data: People › Erase
- Refund: Money › Refund

Closing

- Follow the 5 steps in section 9
- Keep the final exports with the board minutes

18 File index

Everything is in Community_Fund_Website_v3.2.zip. Setup steps are in README.md.

PATH	WHAT IT IS
`docs/Blueprint.pdf`	This document
`docs/LAUNCH_CHECKLIST.md`	Accounts, configuration, 27 test-mode checks, go-live and handover
`docs/HANDOVER.md`	Account ownership, new keys, confirming the handover; inviting and removing a developer later
`scripts/verify-deploy.mjs`	Post-deploy security and configuration check (`npm run verify`)
`public/`	Pages: home, transparency, stats, updates, live-local-act, park, privacy, share, thanks, admin, 404; robots, sitemap, llms.txt, manifest, icons
`public/assets/js/`	common, home, prompts, transparency, stats, updates, share, thanks, admin
`netlify/functions/`	ledger, ledger-csv, pledge, checkout, stripe-webhook, refund, notify, updates, my-share, staff, config, give, plan, health
`netlify/lib/`	util (helpers, staff check, activity logging, Stripe client), giving (limits, pledges, plans, checkout), email (templates and sending)
`supabase/schema.sql`	Tables, rules, triggers, database functions; safe to re-run and upgrades older versions
`tests/`	unit, db, e2e (with screenshots script), live-page
`live-page/`	The Claude-hosted fund page (updated version, not yet published)
`netlify.toml, package.json, .env.example, scripts/`	Build, security headers, dependencies, settings template, pre-deploy check, domain switch

19 Giving plans, limits and goal prompts

Neighbors can give a little at a time. The treasurer decides the limits and goals, and the home page says what it will take to reach the next one.

Giving plans

- Every week, every month or every 3 months, 2 to 24 payments (treasurer sets the maximum)
- The pledge is the plan's total; each payment is a receipt linked to the plan, emailed as "payment 2 of 6"
- Card plans are Stripe subscriptions; after the last payment the server ends the subscription so the card is never charged again
- A declined payment marks the plan "Payment failed" and emails the donor once
- Stopping a plan (donor or treasurer) ends it in Stripe and shrinks the pledge to what was given
- Hand-collected plans: recorders enter the plan; each check or cash deposit is applied to it

Treasurer controls (Settings)

- Smallest gift or payment; largest single card payment (bigger pledges are paid in parts); largest website pledge; largest hand-recorded deposit
- Giving plans on or off; most payments per plan; suggested amounts
- Goals: add, raise, lower or remove (up to 10)
- Goal prompts: on or off, headline, target date
- Every limit is enforced by the database, not just the page, and each change is in the activity log

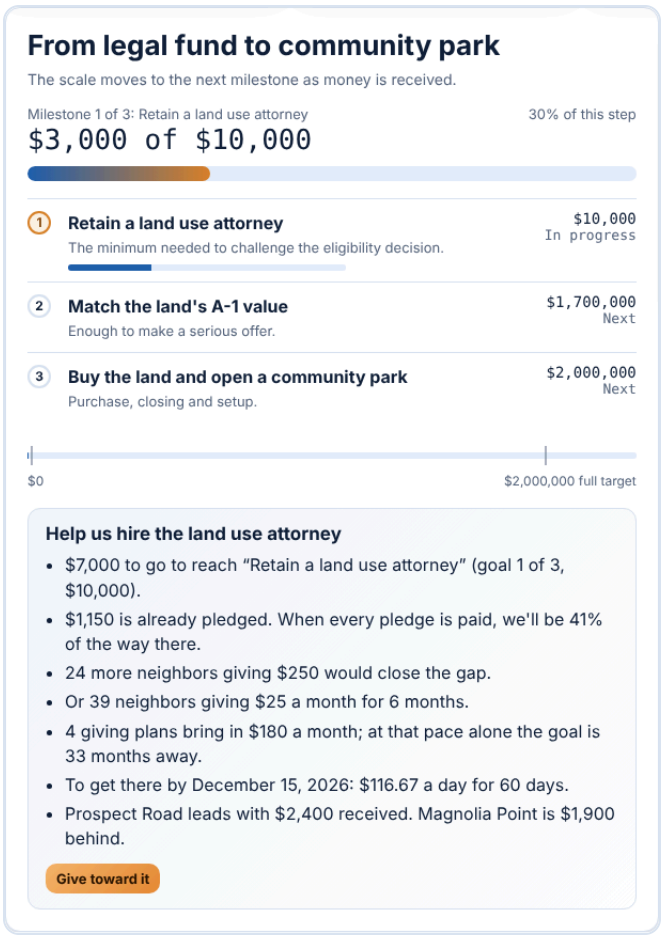


Figure A. "What it will take", worked out from the live figures (sample data).

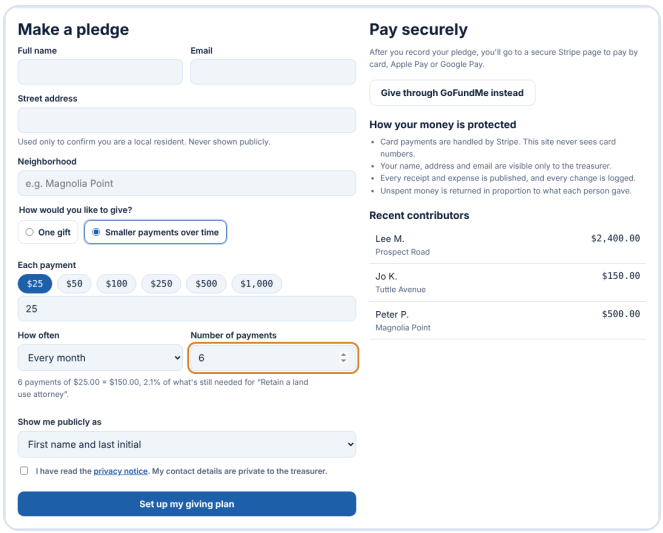


Figure B. Choosing smaller payments over time.

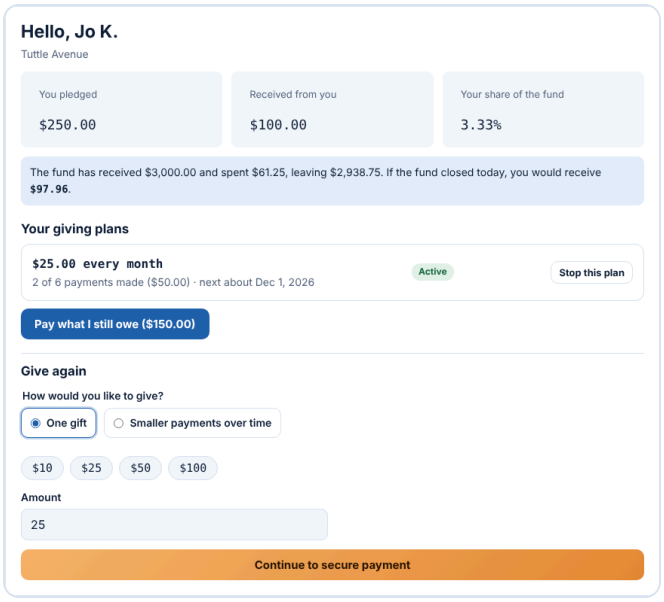


Figure C. A donor's private page: plans, pay what is owed, give again.

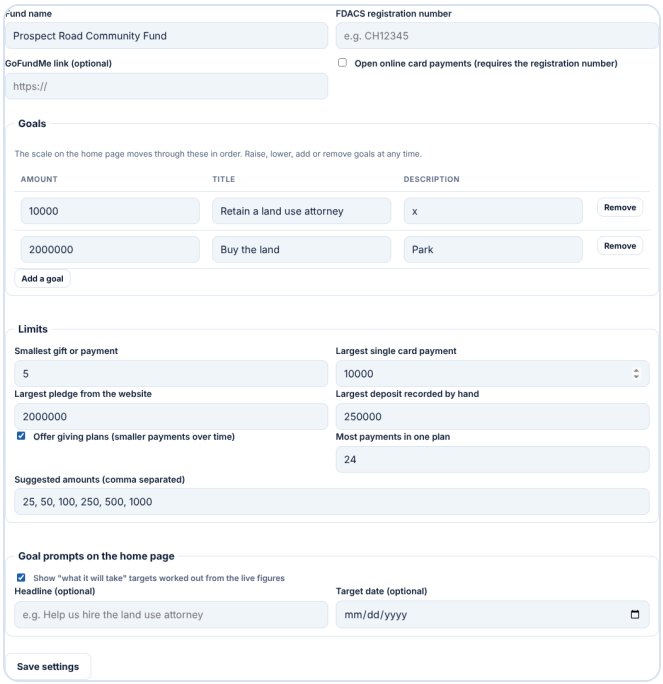


Figure D. Settings: goals, limits and prompts.

20 Developer access, handover and activity log

The fund owns everything. A developer gets in only when the treasurer invites them, sees no personal data, and is out when the time is up or the treasurer says so.

STAGE	WHAT HAPPENS
Handover	Every account (Netlify, Supabase, Stripe, Resend, Cloudflare, domain, code) moved to the fund's shared mailbox; developer removed; every key replaced; health check passes; treasurer confirms in the console, which removes all developer access and logs it (`docs/HANDOVER.md`)
Invite to fix an issue	Team › Developer › 1 to 30 days and the issue. One developer at a time; not a team seat. They see System and activity only
Remove at any time	"Remove access now": access ends immediately and the developer is blocked from even requesting a sign-in code. Access also ends on its own at the end date
After a fix	Replace any key the developer saw and confirm the handover again

Activity log

Separate from the audit log of money and records: who signed in or out, downloads, team, settings and limit changes, developer invitations and removals, handovers, refused access attempts (address kept only as a one-way fingerprint), unknown private links, forged payment notices, declined plan payments and server errors. Nobody can edit or delete it, and each entry is sealed to the one before it. The treasurer sees a banner when there were problems in the last 7 days.

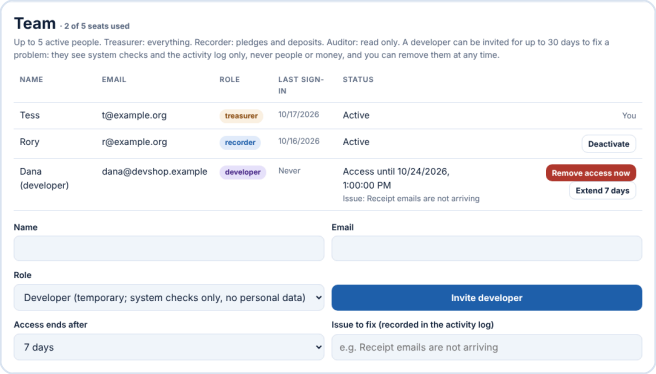


Figure E. Team: inviting a developer for a set time; removing one.

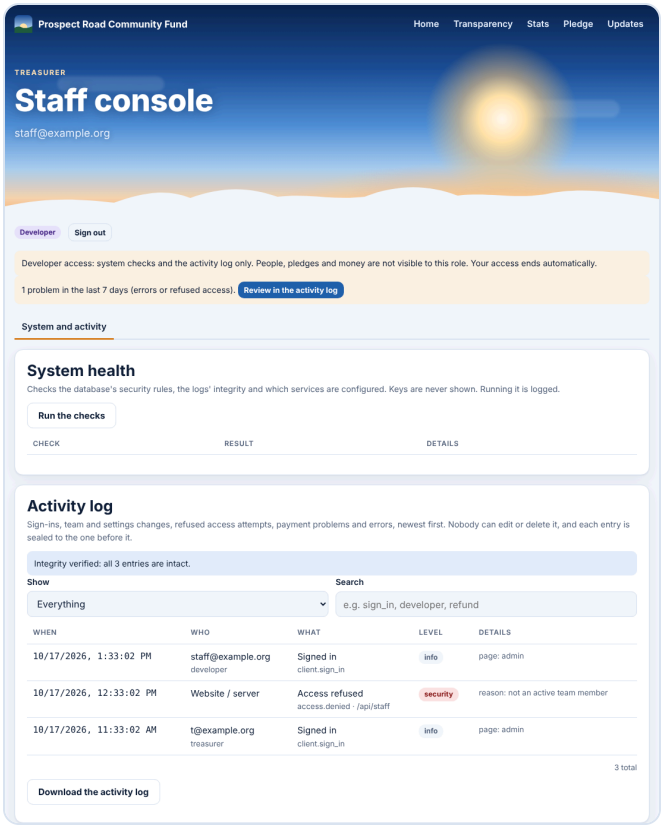


Figure F. What a developer sees: system checks and the activity log only.

System health

Checks the database's security rules, the logs' integrity and which services are configured. Keys are never shown. Running it is logged.

Run the checks

Every security check passed.

CHECK	RESULT	DETAILS
Row Level Security on every table	Passed	
The public (anon) key can read or change no table	Passed	
The public (anon) key can run no database function	Passed	
Every privileged function has a fixed search path	Passed	
At least one active treasurer	Passed	
No more than 5 active team members	Passed	
Audit log intact	Passed	
Activity log intact	Passed	
Card payments only with a state registration	Passed	
Developer access	Passed	1 developer with access until 2026-10-24 17:00

Version a1b2c3d (production) · Stripe live mode · All services configured · 1 problem in 7 days.

Developer handover

When the developer has finished, the fund must own every account and every key must be changed, so nothing the developer knew still works. Tick each step, then confirm. Confirming removes all developer access at once; you can invite a developer again later to fix an issue.

- ☐ **Netlify site, Supabase project, Stripe account, Resend, Cloudflare and the domain are owned by the fund's shared mailbox, and the developer is removed from each**
- ☐ **Code repository transferred to the fund (developer removed or read-only)**
- ☐ **New Supabase service-role key, Stripe secret key, Stripe webhook secret, Resend key and Turnstile secret created and saved in Netlify; old ones deleted**
- ☐ **Database password reset and two-factor sign-in on for every account**
- ☐ **System health shows every check passed after the new keys**

Date the keys were changed

10/17/2026 Confirm handover complete

No handover has been confirmed yet.

Activity log

Sign-ins, team and settings changes, refused access attempts, payment problems and errors, newest first. Nobody can edit or delete it, and each entry is sealed to the one before it.

Integrity verified: all 3 entries are intact.

Show Everything **Search** e.g. sign_in, developer, refund

WHEN	WHO	WHAT	LEVEL	DETAILS
10/17/2026, 1:32:59 PM	staff@example.org treasurer	Signed in client.sign_in	info	page: admin
10/17/2026, 12:32:59 PM	Website / server	Access refused access.denied · /api/staff	security	reason: not an active team member
10/17/2026, 11:32:59 AM	t@example.org treasurer	Signed in client.sign_in	info	page: admin

3 total

Download the activity log

Figure G. System health, the handover checklist and the activity log.